



2016 中国互联网安全大会
China Internet Security Conference

协同联动 共建安全⁺命运共同体

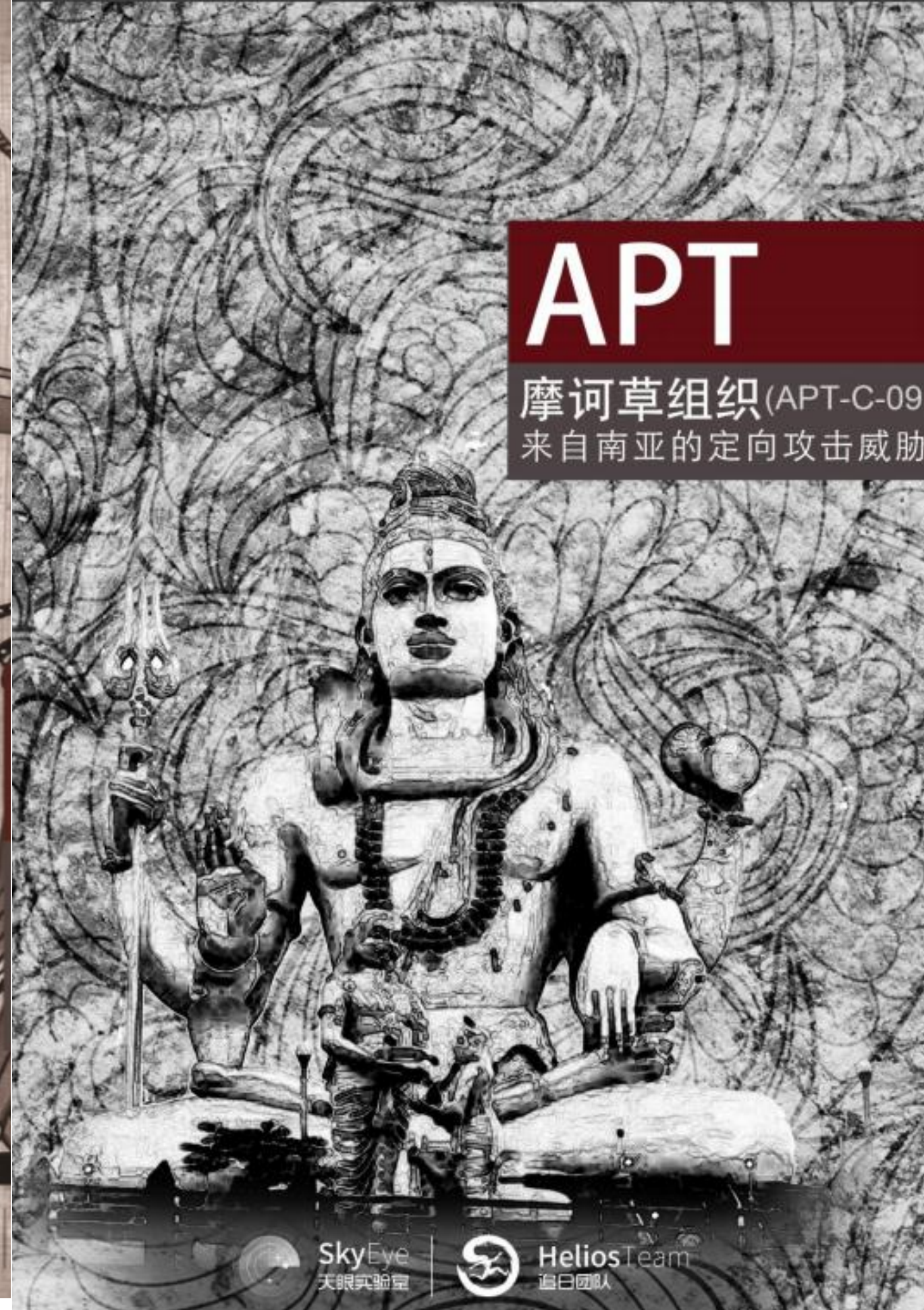
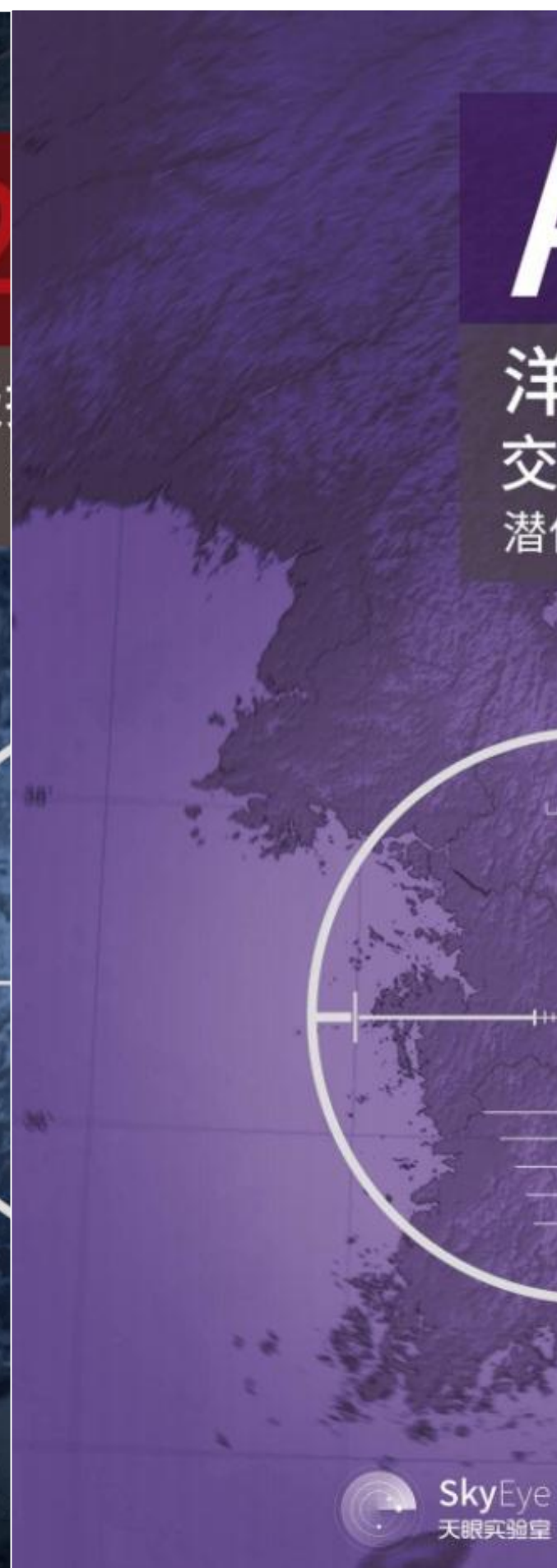
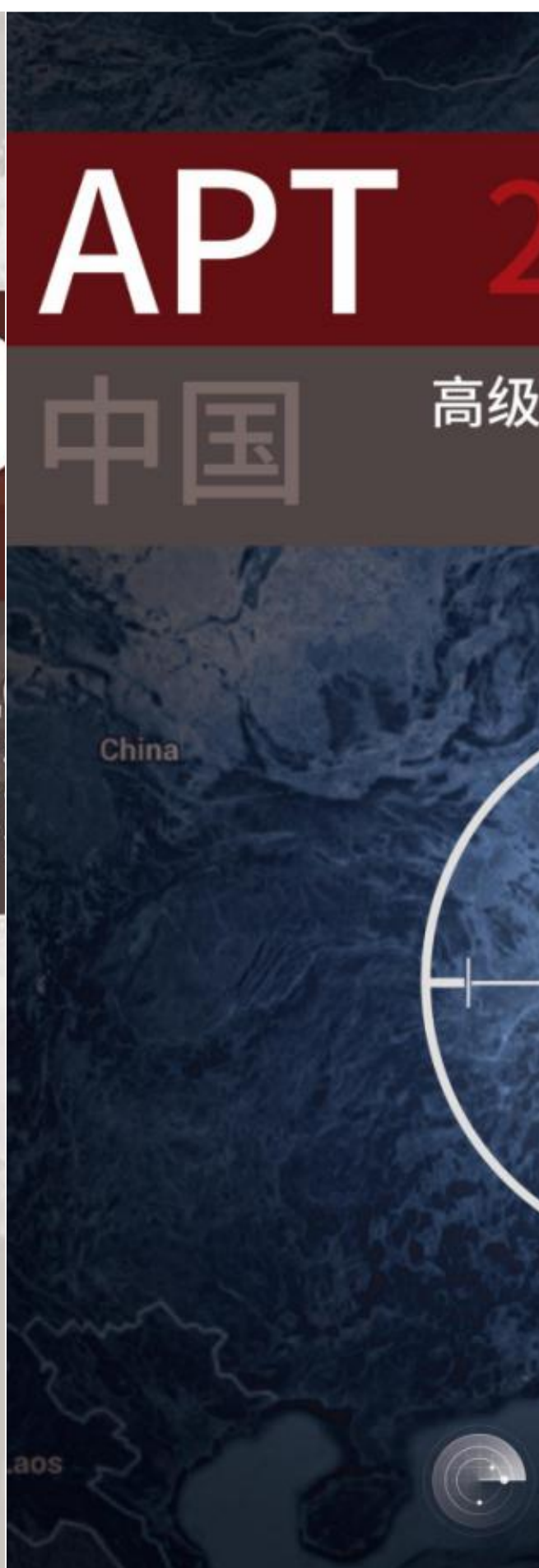
兵者诡道：APT攻击中的虚假情报

胡星儒 | 360追日团队

- 专注APT等高级威胁的研究。
- 致力于发现和披露更多的APT组织或行动。
- 截至目前已发现三十多个APT组织。

发布时间	报告名称	APT编号
2015.05.29	海莲花：数字海洋的游猎者	APT-C-00
2015.12.10	007黑客组织及地下黑产活动分析报告	
2016.01.18	2015年中国高级持续性威胁（APT）研究报告	
2016.05.10	洋葱狗：交通能源的觊觎者潜伏3年的定向攻击威胁	APT-C-03
2016.05.30	美人鱼行动——长达6年的境外定向攻击活动揭露	APT-C-07
2016.06.03	SWIFT之殇：针对越南先锋银行的黑客攻击技术初探	APT-C-26
2016.07.01	人面狮行动——中东地区的定向攻击活动	APT-C-15
2016.07.21	台湾第一银行ATM机“自动吐钱”事件分析	
2016.08.04	摩诃草组织——来自南亚的定向攻击威胁	APT-C-09
2016.08.09	关于近期曝光的针对银行SWIFT系统攻击事件综合分析	APT-C-26
2016.08.11	索伦之眼	APT-C-16

关于360追日团队 (Helios Team)





中国互联网安全大会



360互联网安全中心

目录

APT发展现状

相关案例分析

影响和应对



中国互联网安全大会



360互联网安全中心

目录

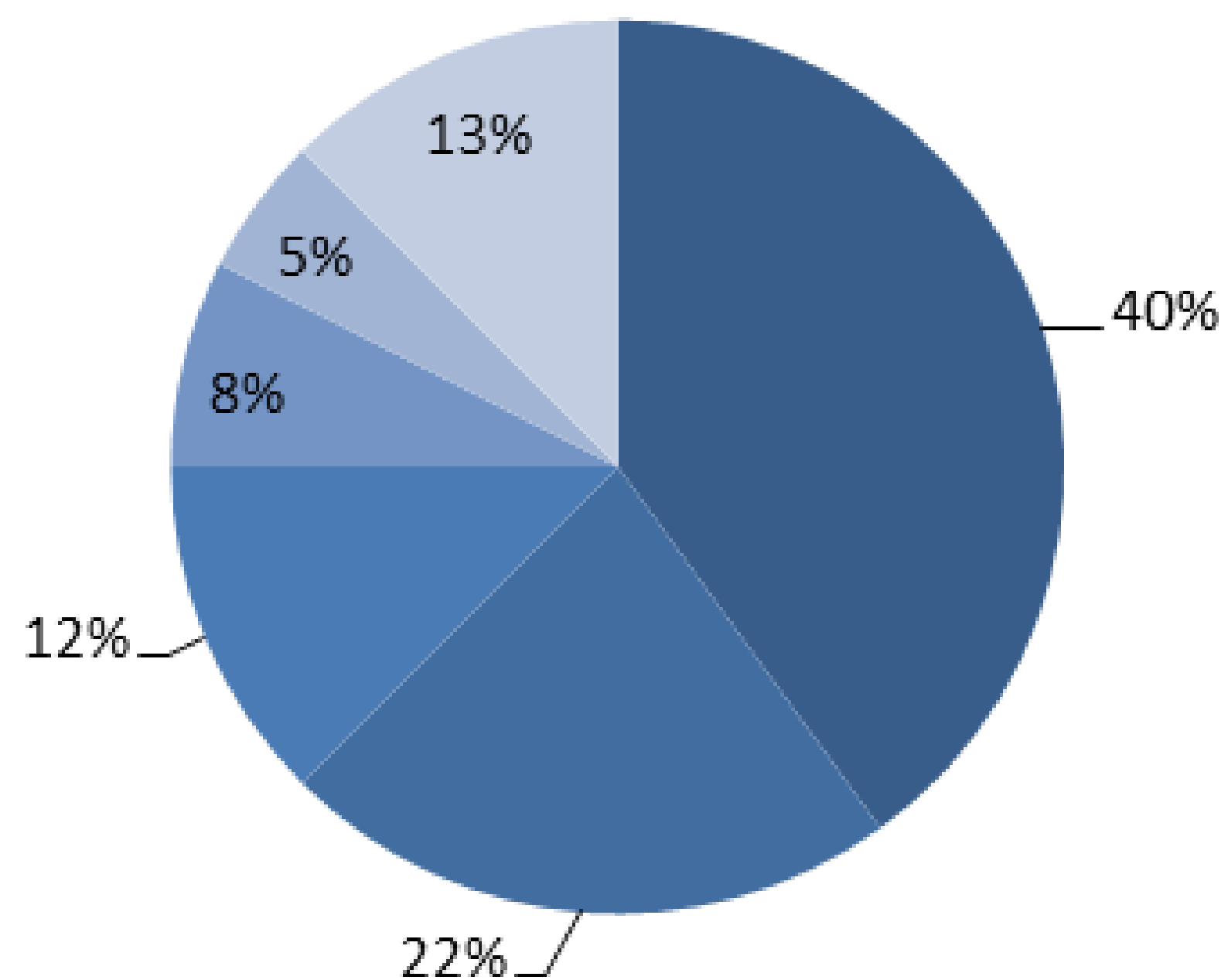
APT发展现状

相关案例分析

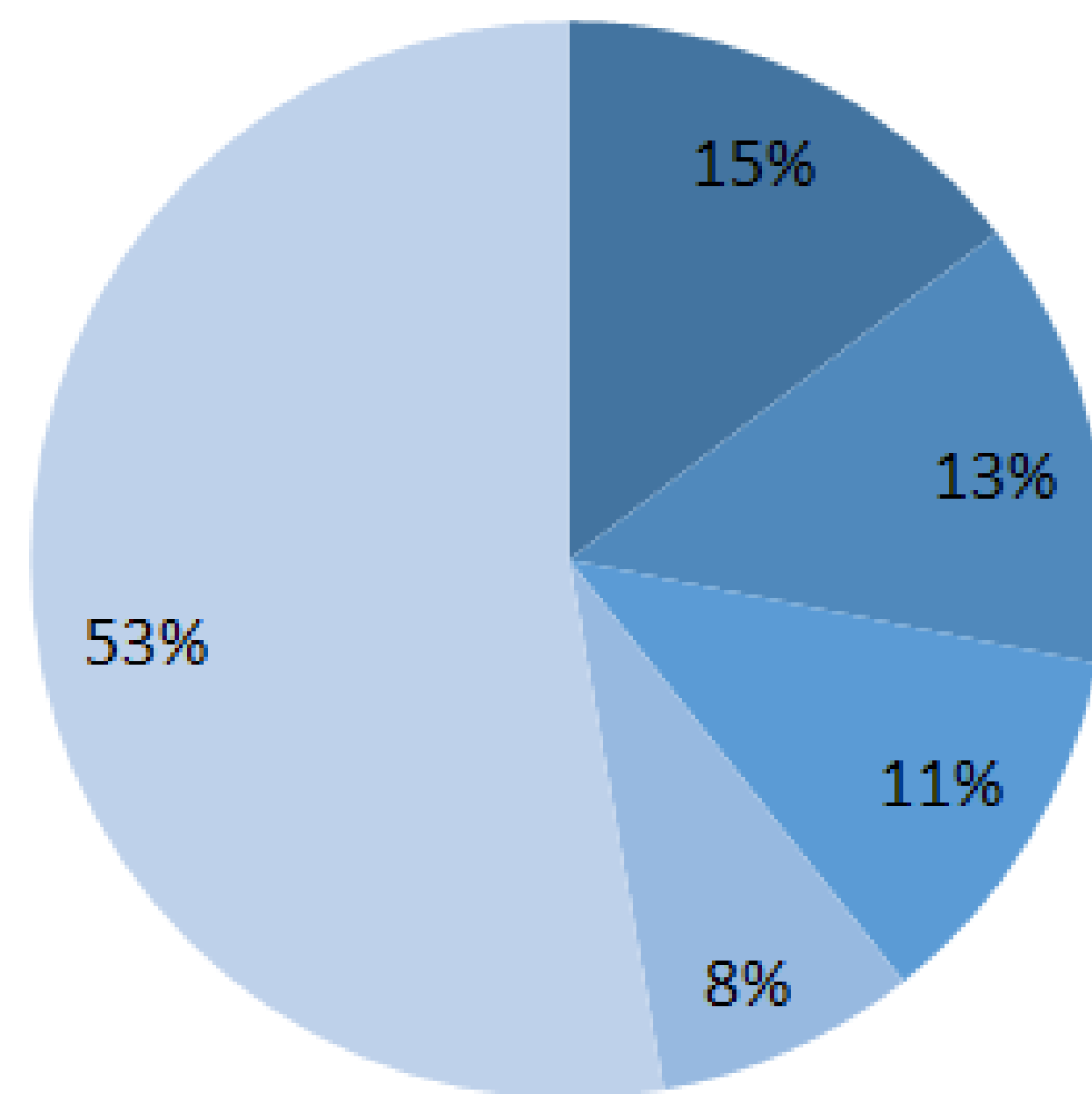
影响和应对

- 全球APT攻击依然活跃，针对中国的APT攻击持续增长。
- **2016年新披露的：**
 - Lazarus：涉及中国地区
 - 摩诃草（hangover、白象）：主要针对中国地区
 - 索伦之眼：主要针对中国地区
- **已披露且2016年活跃的：**
 - 海莲花、Darkhotel、APT28、Carbanak.....

- 全球APT攻击领域关注政府、能源等，针对中国主要是科研教育和政府机构。



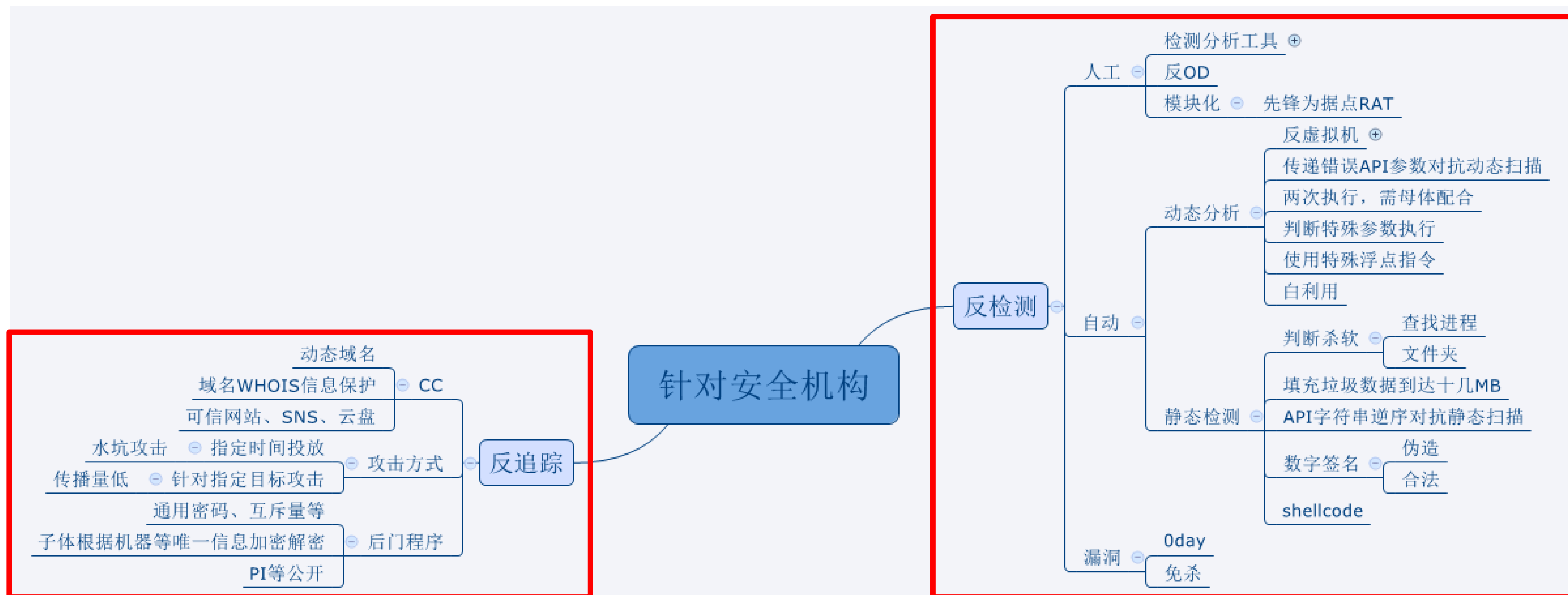
■ 科研教育 ■ 军事 ■ 政府机构
■ 商业 ■ 新闻媒体 ■ 其他



■ 科研教育 ■ 军事 ■ 基础建设 ■ 政府机构 ■ 其他

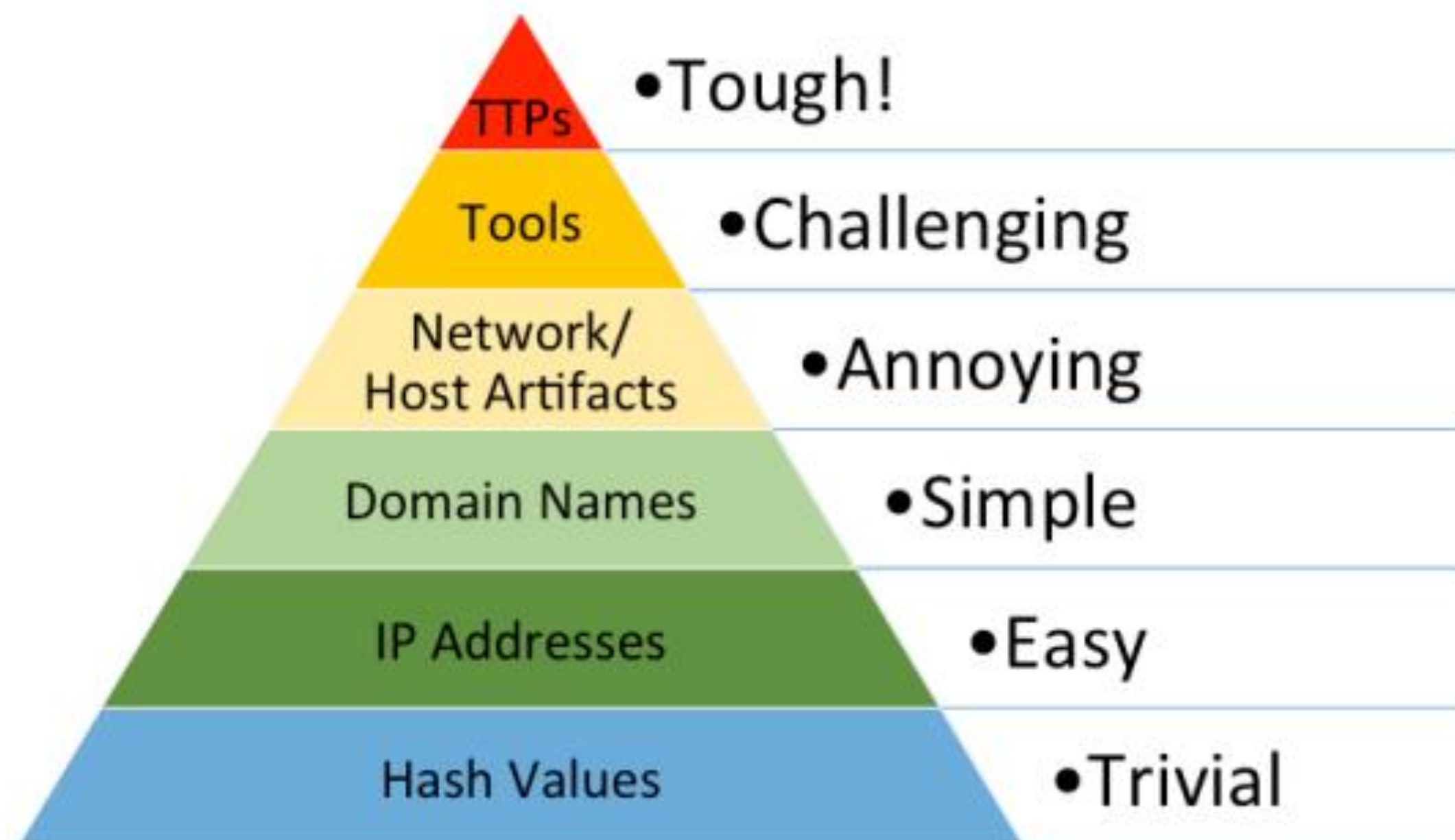
- 全球APT攻击依然活跃，针对中国的APT攻击持续增长。
- 全球APT攻击领域关注政府、能源等，针对中国主要是科研教育和政府机构。
- 针对金融领域的攻击不断出现。
-
- **攻击对抗由被动隐匿到主动出击**

• 对抗手法-针对安全机构



• 幕后组织

- 难以定性，另外存在嫁祸、假情报等情况：
- 客观陈述，避免主观臆断



Mimicry
(拟态)

Lure
(诱饵)

Obfuscation
(混淆)

Disinformation
(假情报)

False flag
(假旗行动)

Counterintelligence
(反情报)

Mislead
(误导)

Feigned activity
(佯动)

Deception
(欺骗)

Disguise
(伪装)

Interference
(干扰)

- **非技术概念**

- **特殊背景**

- **意图：攻击从未停歇**

- **能力：攻击“不计成本”**

- 0day

- 针对性

- 不以获取经济利益为目的

- 高度隐蔽

- 窃取和破坏

- 针对不同平台

-



中国互联网安全大会



360互联网安全中心

目录

APT发展现状

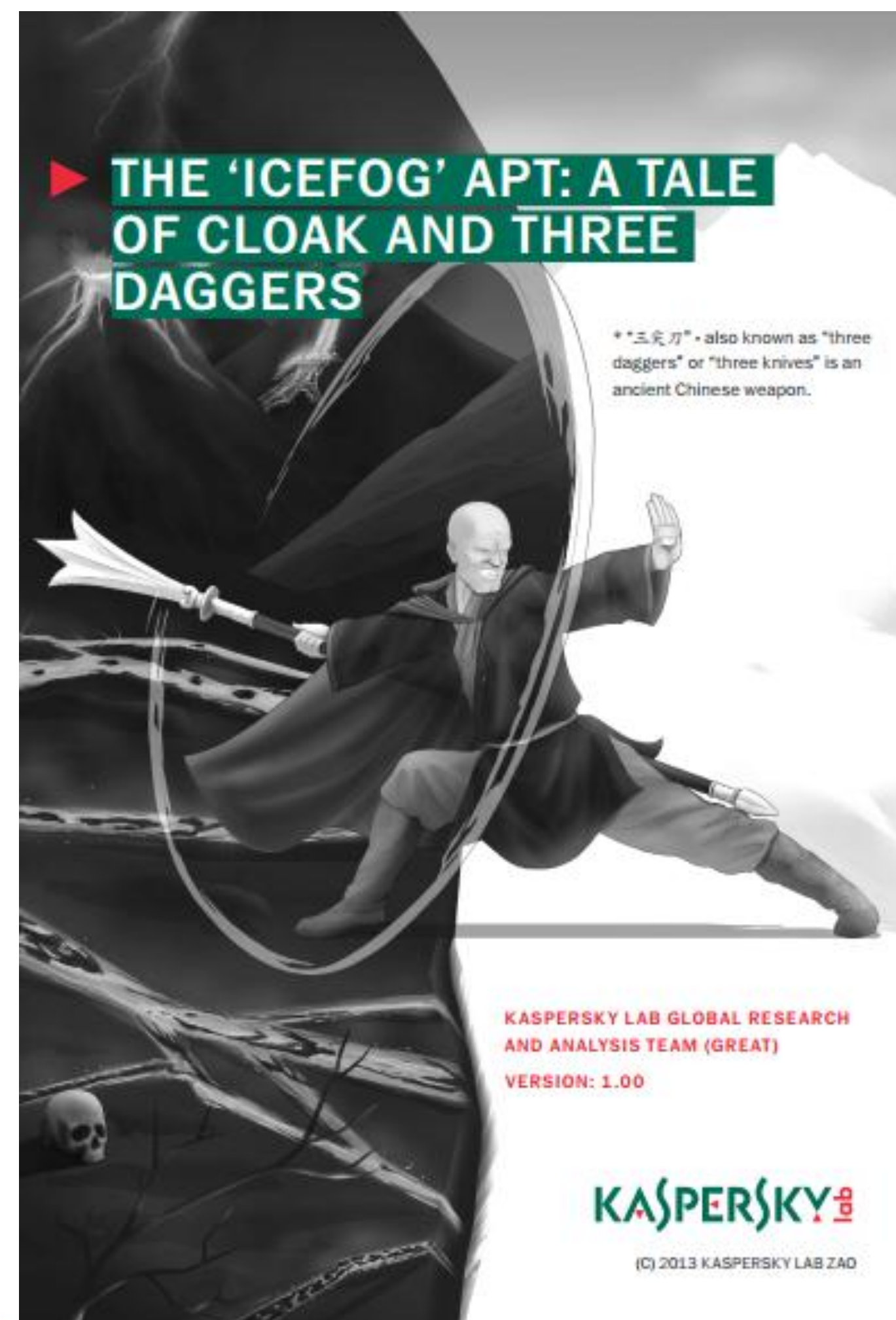
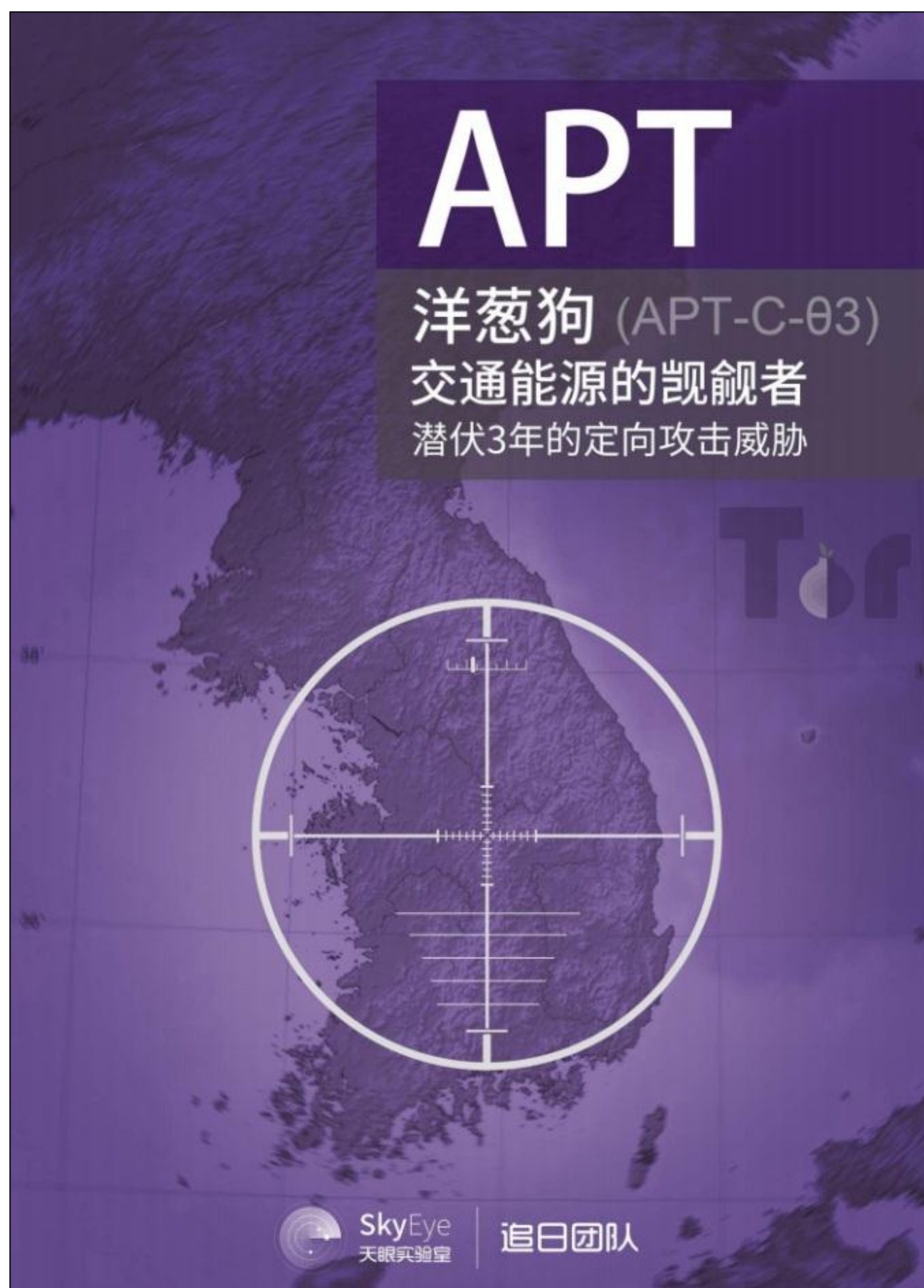
相关案例分析

影响和应对

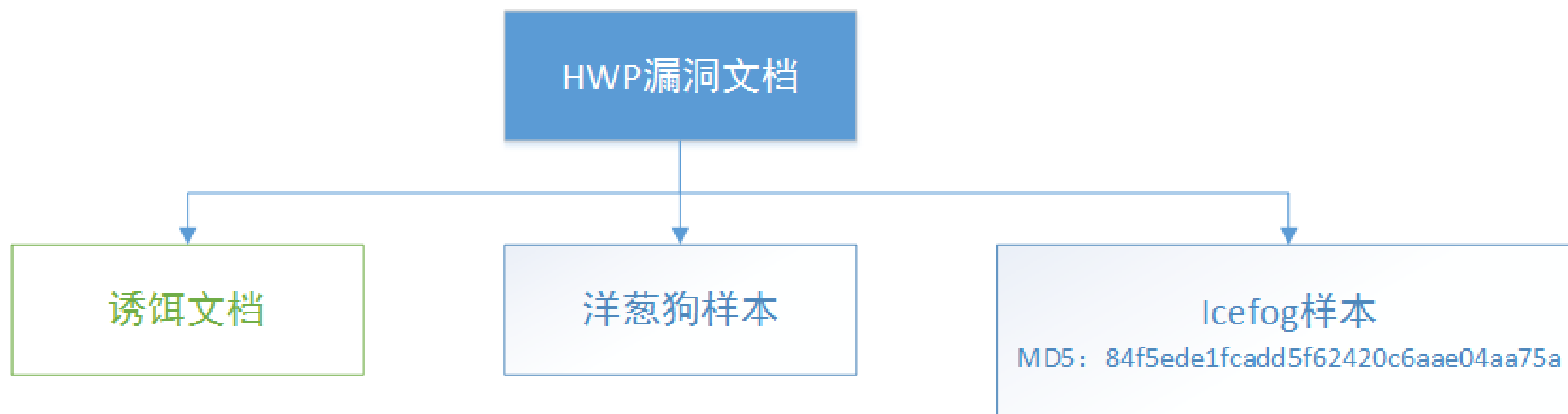


- 预先设定：样本实体文件、C&C域名、特殊字符串、上线密码、诱饵文档属性信息.....
- 事后掩盖：域名WHOIS、IP.....

案例1：洋葱狗和ICEFOG

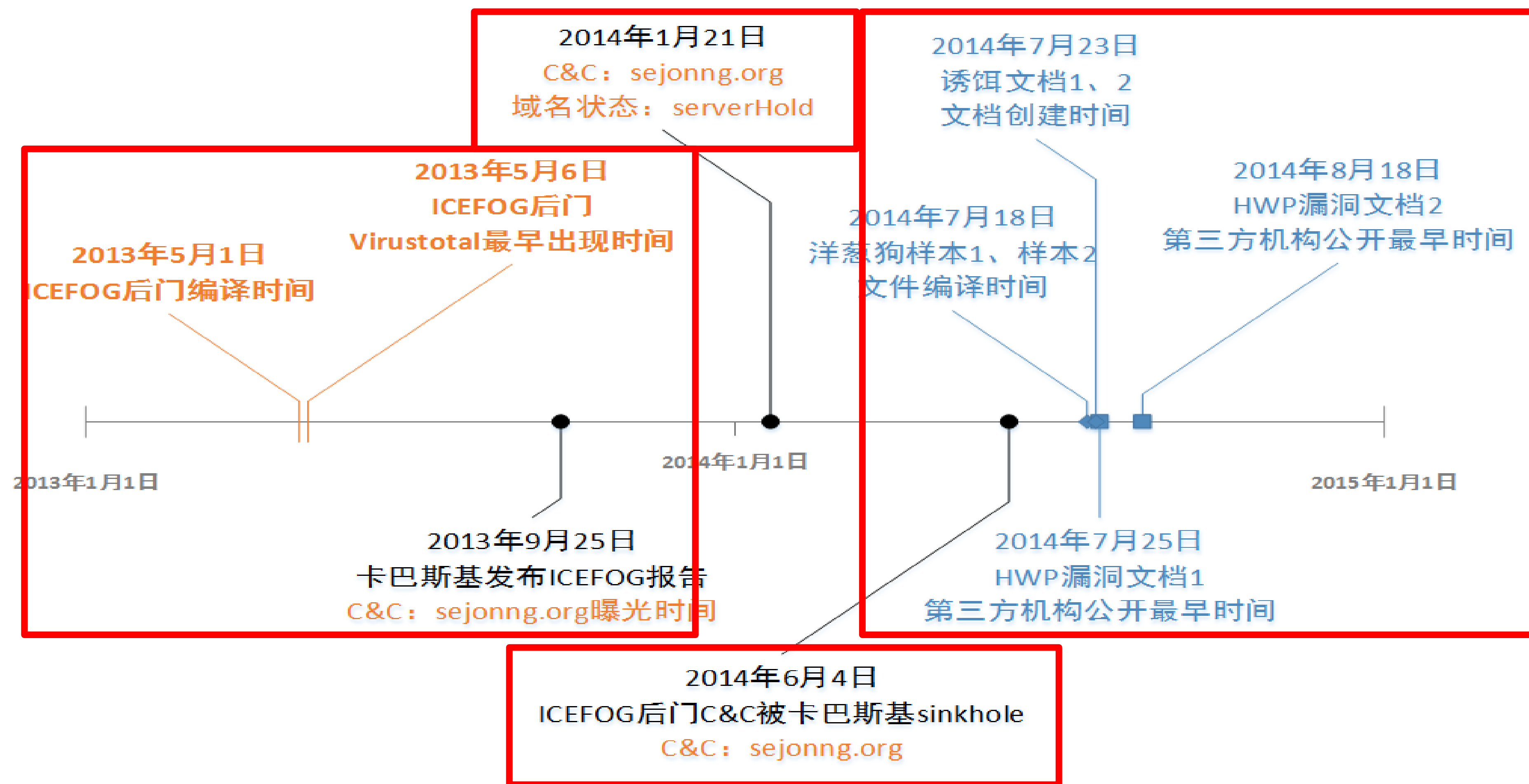


案例1：洋葱狗和ICEFOG



- 不会释放并执行ICEFOG样本
- ICEFOG事件已被披露

案例1：洋葱狗和ICEFOG



案例2 : DUQU2.0

ATTRIBUTION

As usual, attribution of cyberattacks over the Internet is a difficult task. In the case of Duqu, the attackers use multiple proxies and jumping points to mask their connections. This makes tracking an extremely complex problem.

Additionally, the attackers have tried to include several false flags throughout the code, designed to send researchers in the wrong direction. For instance, one of the drivers contains the string "ugly.gorilla", which obviously refers to "Wang Dong, a Chinese hacker believed to be associated with the APT1/Comment Crew. The usage of the Camellia cypher in the MSI VFSeS, previously seen in APT1-associated Poison Ivy samples is another false flag planted by the attackers to make researchers believe they are dealing with APT1 related malware. The "romanian_antihacker" string used in the "portserv.sys" driver is probably designed to mimic "w00tw00t.at.blackhats.romanian.anti-sec" requests that are often seen in server logs or simply point to an alleged Romanian origin of the attack. The usage of rare compression algorithms can also be deceptive. For instance, the LZJB algorithm used in some of the samples is rarely seen in malware samples; it has been used by MiniDuke which we reported in early 2013.

案例3（疑似）：SWIFT事件和Lazarus

孟加拉国央行

```
u1 = CreateFileA(lpFileName, 0x00000000, 0, 0, 3u,
u2 = u1;
IF ( u1 == (HANDLE)-1 )
{
    result = GetLastError();
}
else
{
    SetFilePointer(u1, -1, 0, 2u);
    WriteFile(u2, &buffer, 5u, &numberOfBytesWritten,
    FlushFileBuffers(u2);
    FileSize = 0i64;
    GetFileSizeEx(u2, &FileSize);
    SetFilePointer(u2, 0, 0, 0);
    u = FileSize.HighPart;
    v = FileSize.LowPart;
    u = 0;
    v = 0;
    i = FileSize.HighPart >= 0 && (FileSize.HighPart
    while ( 1 )
    {
        u8 = _DFSUB__( __PAIR__(u4, u5), __PAIR__(u7,
        u11 = u5 - u6;
        u9 = ( __PAIR__(u4, u5) - __PAIR__(unsigned i
        u10 = u5 - u6;
        if ( u9 < 0 || (unsigned __int8)(u9 < 0) " u
        {
            u15 = u9;
        }
        else
        {
            u10 = 4096;
            u15 = 0;
        }
        if ( !WriteFile(u2, &buffer, u10, &numberOfBy
            break;
    }

new
et(&u8, 0, 0x100u);
u9 = 0;
u10 = 0;
strcpy(&Str, lpExistingFileName);
u3 = strrchr(&Str, 92);
if ( u3 )
    u = u3 + 1;
else
    u = &Str;
if ( u4 )
{
    do
    {
        u4 = rand() % 26 + 97;
        u5 = (u4++)[1];
    }
    while ( u5 );
}
if ( MoveFileA(lpExistingFileName, &Str)
    u = &Str;
if ( a2 )
{
    if ( !RemoveDirectoryA((LPCSTR)u2) )
        return GetLastError();
}
else if ( !DeleteFileA((LPCSTR)u2) )
{
    return GetLastError();
}
}
```

越南先锋银行

```
u3 = CreateFileA(lpFileName, 0x00000000, 0
u4 = u3;
IF ( u3 == (HANDLE)-1 )
{
    result = GetLastError();
}
else
{
    SetFilePointer(u3, -1, 0, 2u);
    WriteFile(u4, &buffer, 1u, &numberOfBytesTest
    FlushFileBuffers(u4);
    GetFileSizeEx(u4, &FileSize);
    u6 = 0;
    for ( i = 0; ; u6 = 1 )
    {
        u7 = a2;
        if ( a2 > 6 )
            u7 = 6;
        if ( u6 >= u7 )
            break;
        SetFilePointer(u4, 0, 0, 0);
        if ( *(&u17 + u6) == -1 )
        {
            sub_4003A0(&buffer, 4096);
        }
        else
        {
            LOWORD(u8) = *(&u17 + u6);
            BYTE1(u8) = *(&u17 + u6);
            u9 = u8 << 16;
            LOWORD(u9) = u8;
            memset32(&buffer, u9, 0x400u);
        }
        u10 = FileSize.HighPart;
        u11 = FileSize.LowPart;
        u12 = 0i64;
    }

memset(&u8, 0, 0x100u);
u9 = 0;
u10 = 0;
strcpy(&Str, lpExistingFileName);
u3 = strrchr(&Str, '\\');
if ( u3 )
    u4 = u3 + 1;
else
    u4 = &Str;
if ( u4 )
{
    do
    {
        u4 = rand() % 26 + 97;
        u5 = (u4++)[1];
    }
    while ( u5 );
}
if ( MoveFileA(lpExistingFileName, &Str) )
    u2 = &Str;
if ( a2 )
{
    if ( !RemoveDirectoryA((LPCSTR)u2) )
        return GetLastError();
}
else if ( !DeleteFileA((LPCSTR)u2) )
{
    return GetLastError();
}
return 0;
}
```

Lazarus 组织

```
3 = CreateFileA(Source, 0x00000000, 0, 0, 3,
u4 = u3;
21 = u3;
IF ( u3 == -1 )
{
    result = GetLastError();
}
else
{
    SetFilePointer(u3, -1, 0, 2);
    WriteFile(u4, &dst, 1, &u22, 0);
    FlushFileBuffers(u4);
    GetFileSizeEx(u4, u19);
    u20 = 0;
    while ( 1 )
    {
        u6 = a2;
        if ( a2 > 6 )
            u6 = 6;
        u7 = u20;
        if ( u20 >= u6 )
            break;
        SetFilePointer(u4, 0, 0, 0);
        u8 = *(&u23 + u7);
        if ( u8 == -1 )
            sub_401C82(&dst, 4096);
        else
            memset(&dst, u8, 0x1000u);
        u9 = u19[1];
        for ( i = 0i64; i < *( _QUORD *)u19; i ++
    }

memset(&u7, 0, 0x100u);
u8 = 0;
u9 = 0;
u2 = Source;
strcpy(&dest, Source);
u3 = strrchr(&dest, 92);
if ( u3 )
{
    u3 = &dest;
    goto LABEL_A;
}
while ( 1 )
{
    ++u3;
    LABEL_A:
    if ( !u3 )
        break;
    u3 = rand() % 26 + 97;
}
if ( MoveFileA(Source, &dest) )
    u2 = &dest;
if ( a2 )
    u4 = RemoveDirectoryA(u2);
else
    u4 = DeleteFileA(u2);
if ( u4 )
    result = 0;
else
    result = GetLastError();
return result;
}
```

Backdoor.Fimlis

```
u8 = CreateFileW(a3, 0x00000000, 0, 0, 3,
u9 = u8;
IF ( u8 == -1 )
{
    result = GetLastError();
}
else
{
    SetFilePointer(u8, -1, 0, 2, a2, a1);
    WriteFile(u9, &u20, 1, u20, 0);
    FlushFileBuffers(u9);
    SetFilePointer(u9, 0, 0, 0, u20, u21);
    GetFileSizeEx(u9, &u23);
    for ( i = 0; ; ++i )
    {
        u13 = a6;
        if ( a6 > 6 )
            u13 = 6;
        if ( i >= u13 )
            break;
        if ( u22[i] == -1 )
        {
            sub_401540(&u20, 4096);
        }
        else
        {
            LOWORD(u11) = u22[i];
            BYTE1(u11) = u22[i];
            u14 = u11 << 16;
            LOWORD(u14) = u11;
            memset32(&u20, u14, 0x400u);
        }
        u15 = 0;
        u16 = 0;
    }

CloseHandle(u9);
wcsncpy(&dest, Source);
u18 = wcsrchr(&dest, '\\');
if ( u18 )
    u19 = u18 + 1;
else
    u19 = &dest;
for ( ; *u19; *(u19 - 1) = rand() % 26 + 97 )
    ++u19;
if ( MoveFileW(Source) )
    wcsncpy(Source, u24);
if ( duord_404798() )
    result = 0;
else
    result = GetLastError();
}
return result;
}
```


案例3（疑似）：SWIFT事件和Lazarus

- 安全删除函数：代码复用
- 疑似拼写错误：

事件	描述
Lazarus	<u>Mozillar</u> 写为Mozilla
	security写为 <u>secruity</u>
越南先锋银行	<u>FileOut</u> 写为 <u>FilleOut</u>
孟加拉国央行	already写为 <u>alreay</u>
	Foundation误写为 <u>fandation</u>

其他：摩诃草

- SOA与WHOIS关联

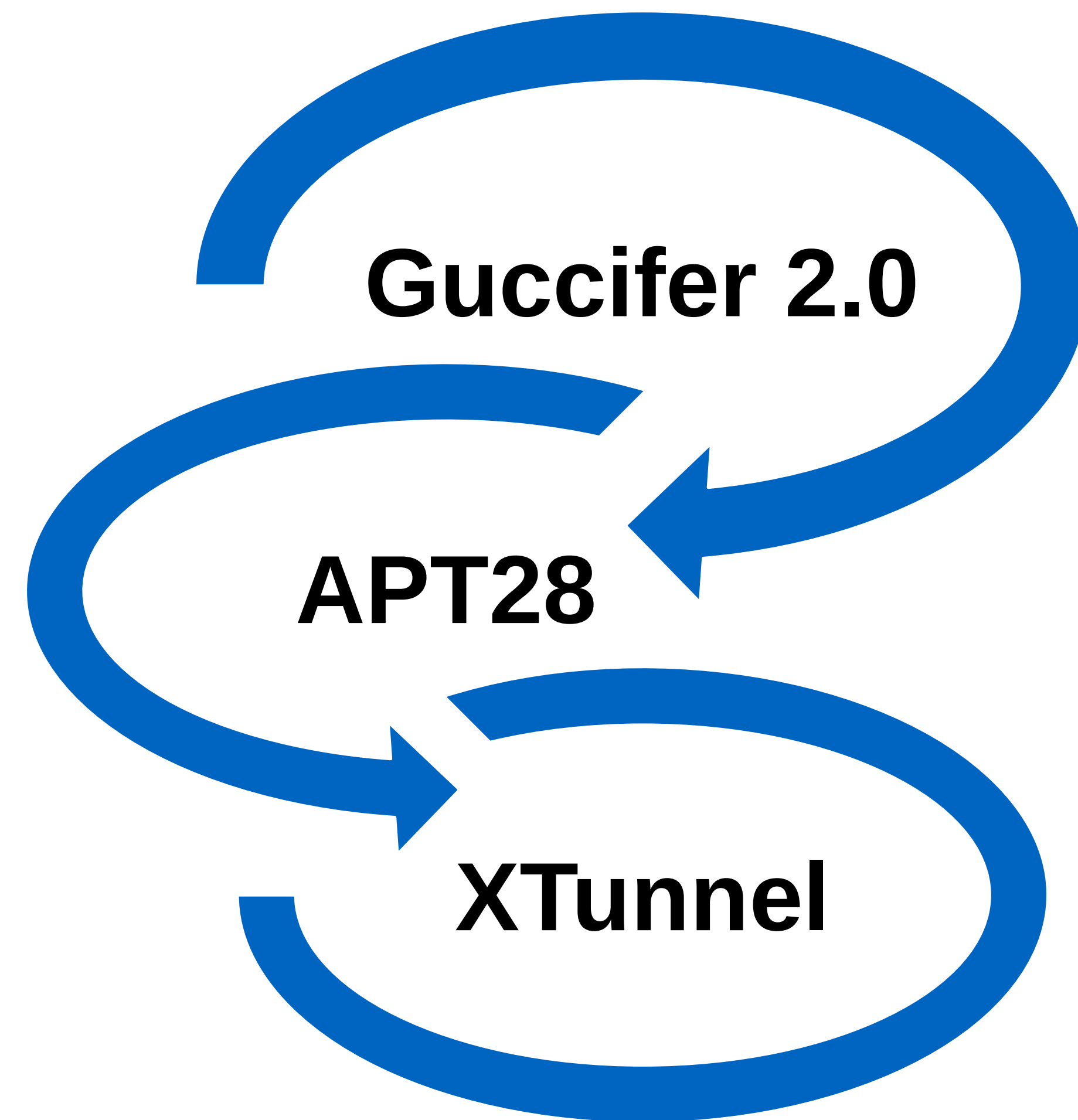
C&C域名	SOA RNAME	IP
revoltmax.com	munna.bhai124@gmail.com	178.162.210.245
blingblingg.com	munna.bhai124@gmail.com	178.162.210.246
eyescreem.com	munna.bhai124@gmail.com	95.211.205.166
outlookkz.com	munna.bhai124@gmail.com	95.211.205.164
dailychina.news	munna.bhai124@gmail.com	178.162.210.247
asiandefnetwork.com	munna.bhai124@gmail.com	178.162.210.248
xbladezz.com	munna.bhai124@gmail.com	178.162.210.243
xmachinez.com	munna.bhai124@gmail.com	178.162.210.242 46.165.229.9

其他：摩诃草

- SOA与WHOIS关联

C&C域名	年份	域名注册邮箱
extrememachine.org	2008	extreme0347@gmail.com
	2011	prajyot2009@gmail.com
		munna.bhai124@gmail.com
	2012	域名保护
pizzapalace.org	2014	sinkhole
	2011	prajyot2009@gmail.com
		munna.bhai124@gmail.com
	2012	域名保护
symantecz.com	2014	sinkhole
	2012	munna.bhai124@gmail.com 域名保护

其他：DNC邮件泄露事件



案例4：美人鱼攻击行动

Sophos Ltd. [GB] <https://community.sophos.com/products/unified-threat-management/f/55/t/46992>

SOPHOS
Community BETA

Search

Sophos UTM 9 > Web Protection: Web Filtering...

My sites, False positive

 **aj58**
Posted: 25 Jul 2015 10:53 PM 6 Comments English

Hello
I made Contact with sophos (<https://secure2.sophos.com/en-us/threat-center/reassessment-request.aspx>) to report false positive, but after many days I have not recive any response.

my reauest was.....
your product detect two of my site as malware.
your latest updated trial version does not detect any file in my sites as malware.
also there is not any binary, program, apk or any dangerous file in my sites.
please remove my sites from your black list as soon as possible
thanks

-----My sites
<http://updateserver1.com>
<http://bestupdateserver.com/>

案例4：美人鱼攻击行动

相关疑点：

- 疑点1：相关C&C窃取信息回传或传输恶意程序；
- 疑点2：与另外8个C&C域名注册邮箱相同；
- 疑点3：与其他C&C一样，都没有WEB服务；
- 疑点4：名下另外3个C&C域名目前已被sinkhole。

- 其他：

相关内容	具体时间
最后一次攻击时间	2015年7月24日
aj58反馈的时间	2015年7月25日

案例5（非APT）：007组织

发件人:

收件人:

抄送:

主题:

木马

这个病毒封杀不了 - 问题

bbs.360safe.com/thread-6202909-1-1.html

首页 论坛 版块 热门活动 校园俱乐部 水滴直播 积分商城 360商城 智能社区 签到

版块 > 360产品 > 360杀毒 > 问题反馈 > 这个病毒封杀不了

问题反馈

★收藏本版 今日: 18 主题: 17672

136 3

发帖

返回列表



xwzf007
积分: 11

[病毒查杀] 这个病毒封杀不了 [复制链接]

发表于 2015-9-10 08:40:57 | 只看该作者

这个样本360一直没封杀掉 运行就访问永硕E盘 (www.ys168.com) 这个网站解析IP 然后根据解析的IP链接控制端 一直无法封杀

 [QQ截图.rar](#) (336.57 KB, 下载次数: 7)

已解决

直达 楼主

其他厂商研究成果

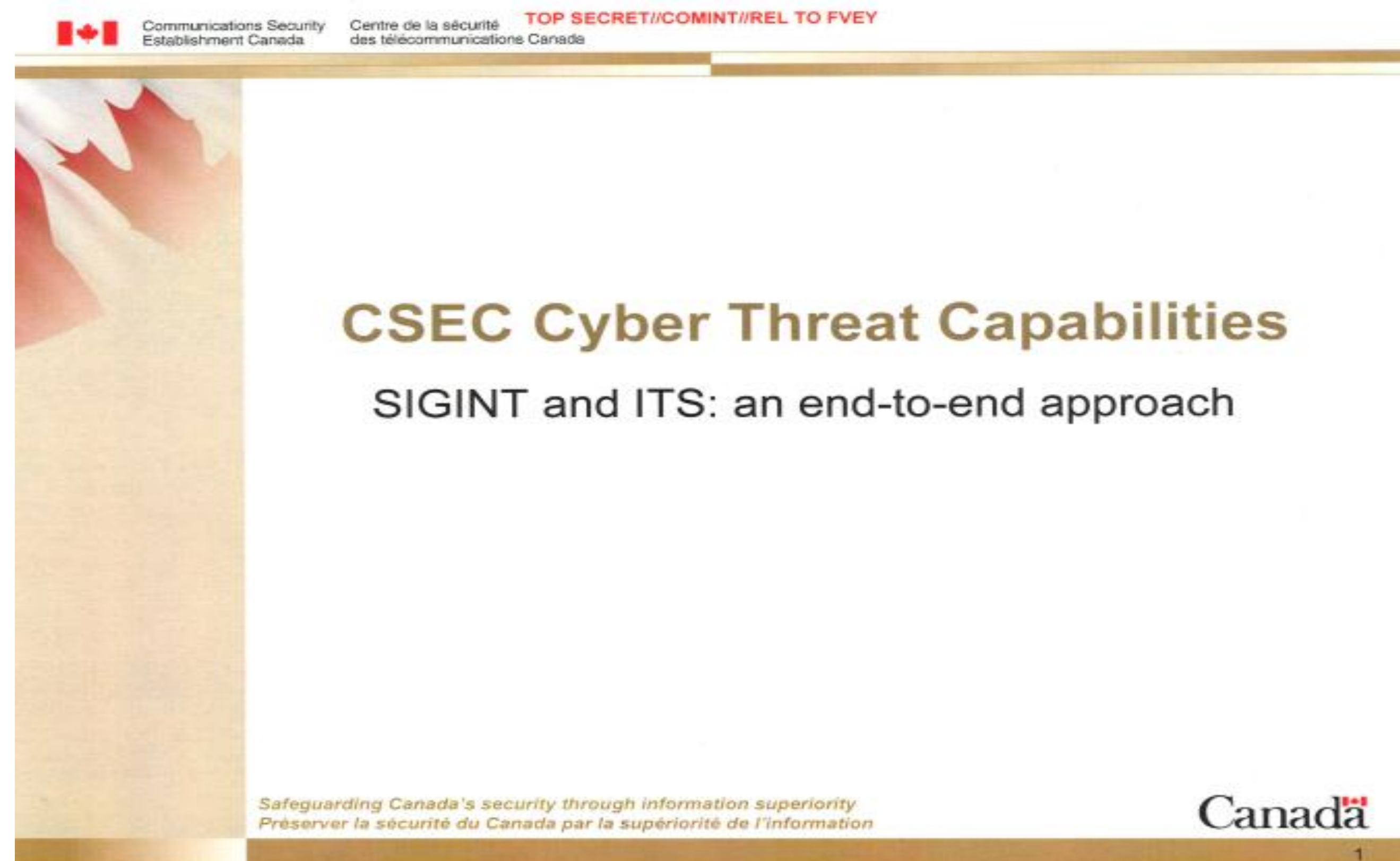
- 完全模仿：Cloud Atlas模仿红色十月相关攻击行动。
- 不同签名：APT28采用不同的签名等来干扰。
- C&C通信：Carbanak相关

FiveEye (五眼)

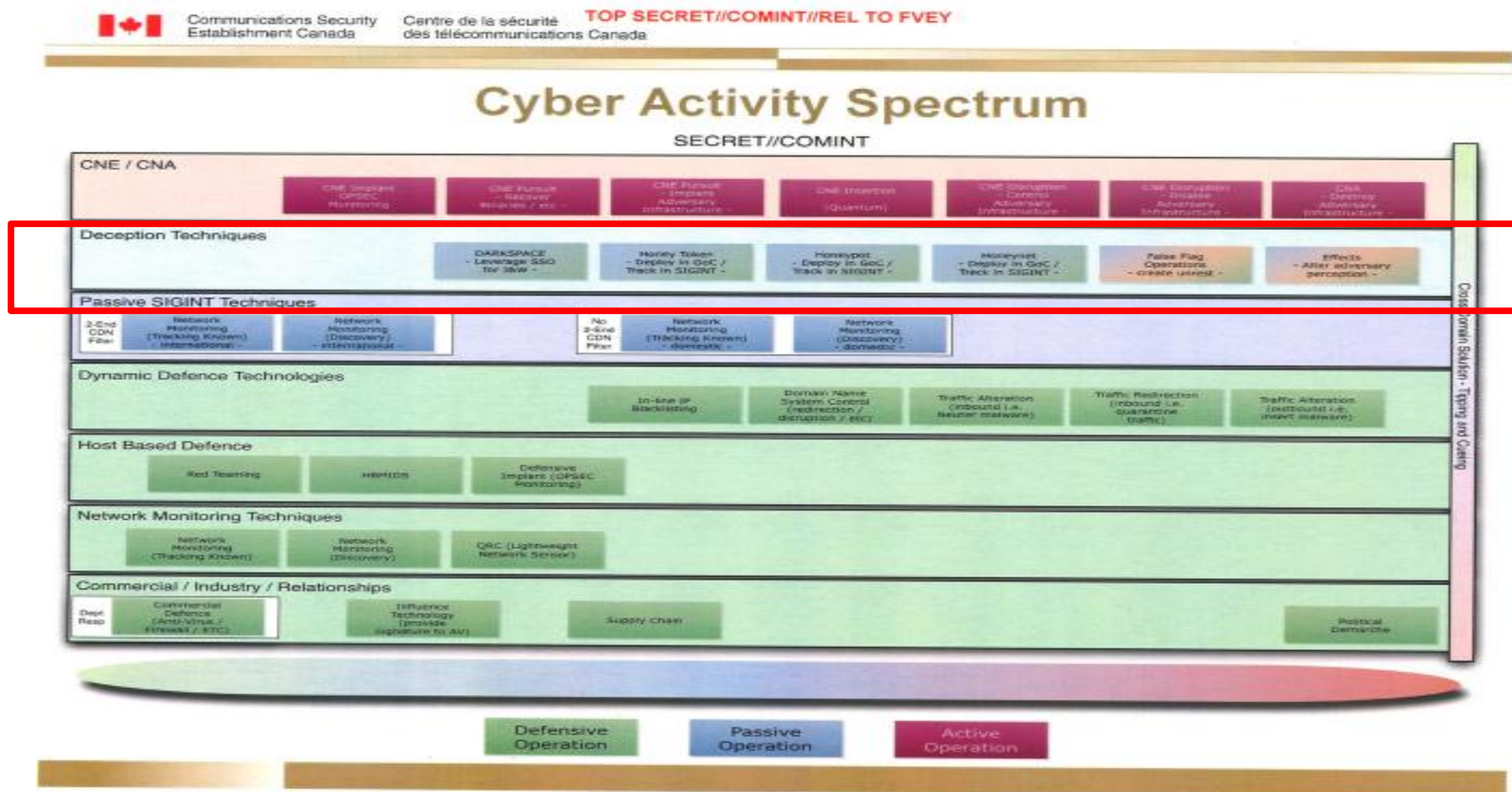
Country	SIGINT
Australia	Australian Signal Directorate – ASD
Canada	Comunications Security Establishment – CSE
New Zealand	Government Communications Security Bureau – GCSB
United Kingdom	Government Communcations Headquarters – GCHQ
United States	National Security Agency – NSA

CSEC (Communications Security Establishment Canada)

- CSEC 网络威胁能力-通信情报和信息技术安全：端对端攻击方式



CSE Cyber Activity Spectrum



Deception Techniques (欺骗技术)

DARKSPACE
- Leverage SSO
for I&W -

Honey Token
- Deploy in GoC /
Track in SIGINT -

Honeypot
- Deploy in GoC /
Track in SIGINT -

Honeynet
- Deploy in GoC /
Track in SIGINT -

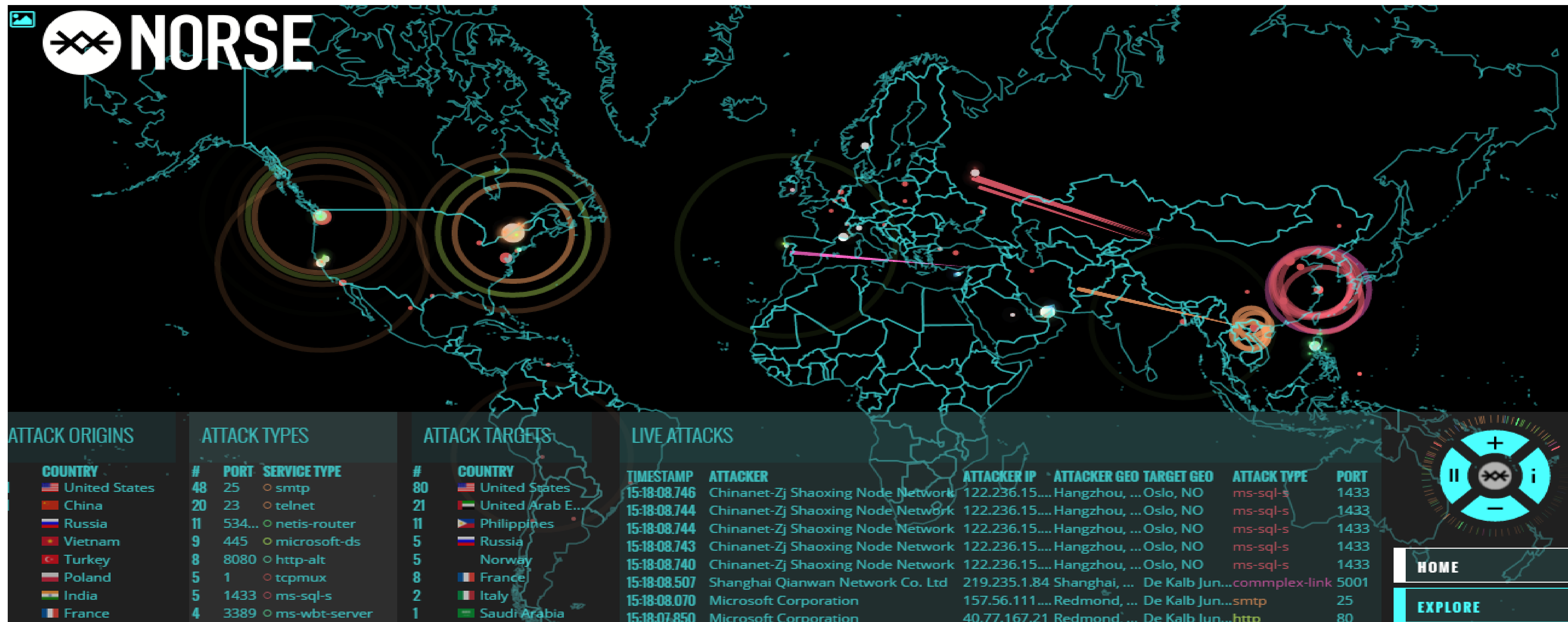
False Flag
Operations
- create unrest -

Effects
- Alter adversary
perception -

False Flag Operations (假旗行动)

- False Flag Operations - Create unrest -
- 假旗攻击 - 制造动荡局面 -
- 一种典型的利用心理学的战术，假旗指的是某个国家或组织发起一次攻击后，却使之看起来像是另有其他国家或者组织所为，目的是为了引起攻击目标和被嫁祸国或被嫁祸组织间的紧张敌对气氛，或者是为了以某种方式使真正的攻击者受益。

Norse Attack Map



Norse Attack Map

- 宫一鸣 《安全威胁情报与基础数据》

- **norse的主要问题**

- 几乎无法提供任何有意义,有价值的信息
- 外行看热闹
- 内行也看热闹!



中国互联网安全大会



360互联网安全中心

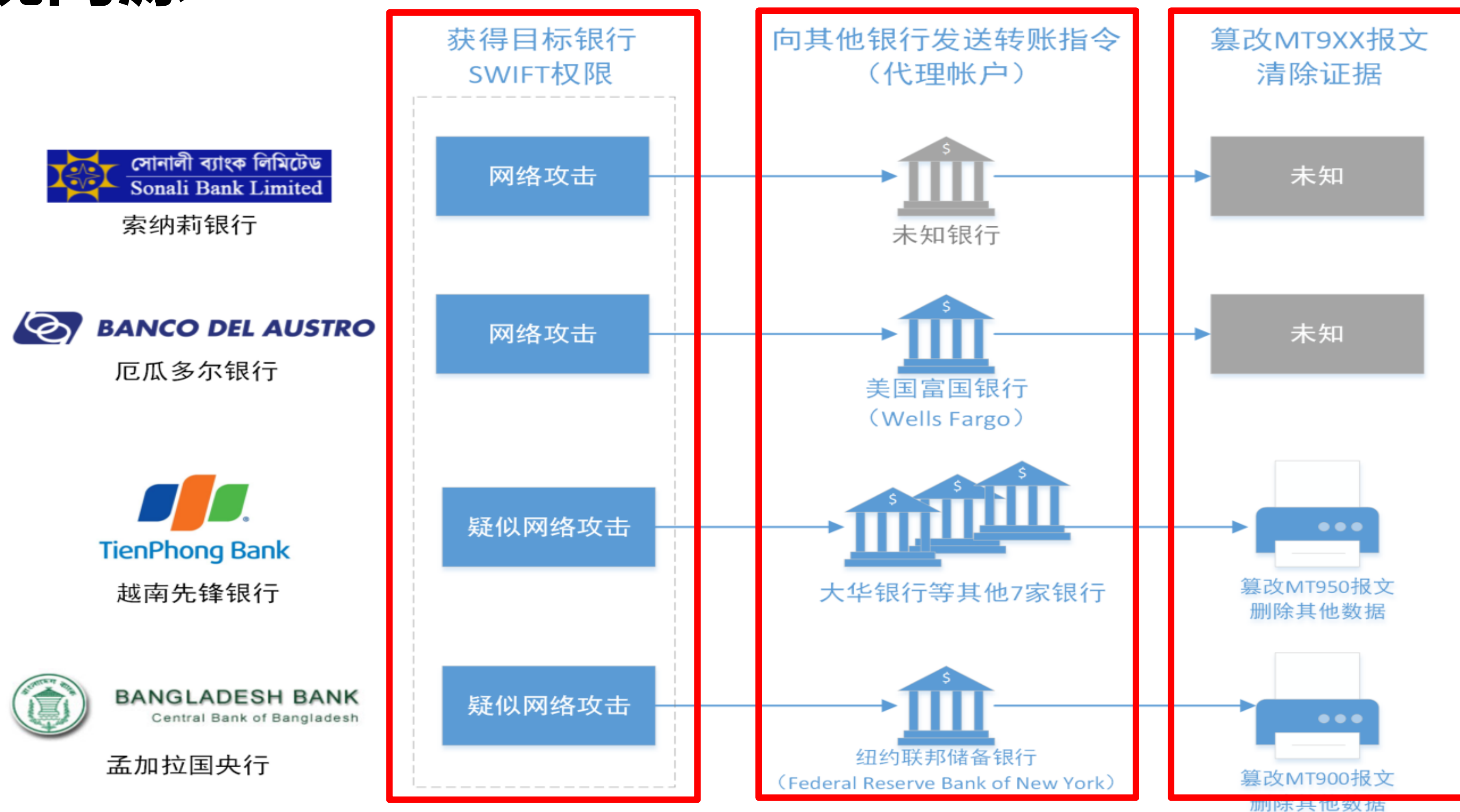
目录

APT发展现状

相关案例分析

影响和应对

发现同源



判断归属

- 一些方法或依据：

语言、工作时区、IP地理位置、地缘政治等



Communications Security Establishment Canada



Communications Security Establishment Canada



Centre de la sécurité des télécommunications Canada

Overall Classification: TOP SECRET // COMINT // REL TO CAN, AUS, GBR, NZL, USA



A

Attribution: Language

- ntrass.e
 - DLL L
 - part of
 - Intern
 - Devel
- Babar is children
- Titi is a Thiery, small pe

Safeguarding Canada's security through information superiority
Préserver la sécurité du Canada par la supériorité de l'information

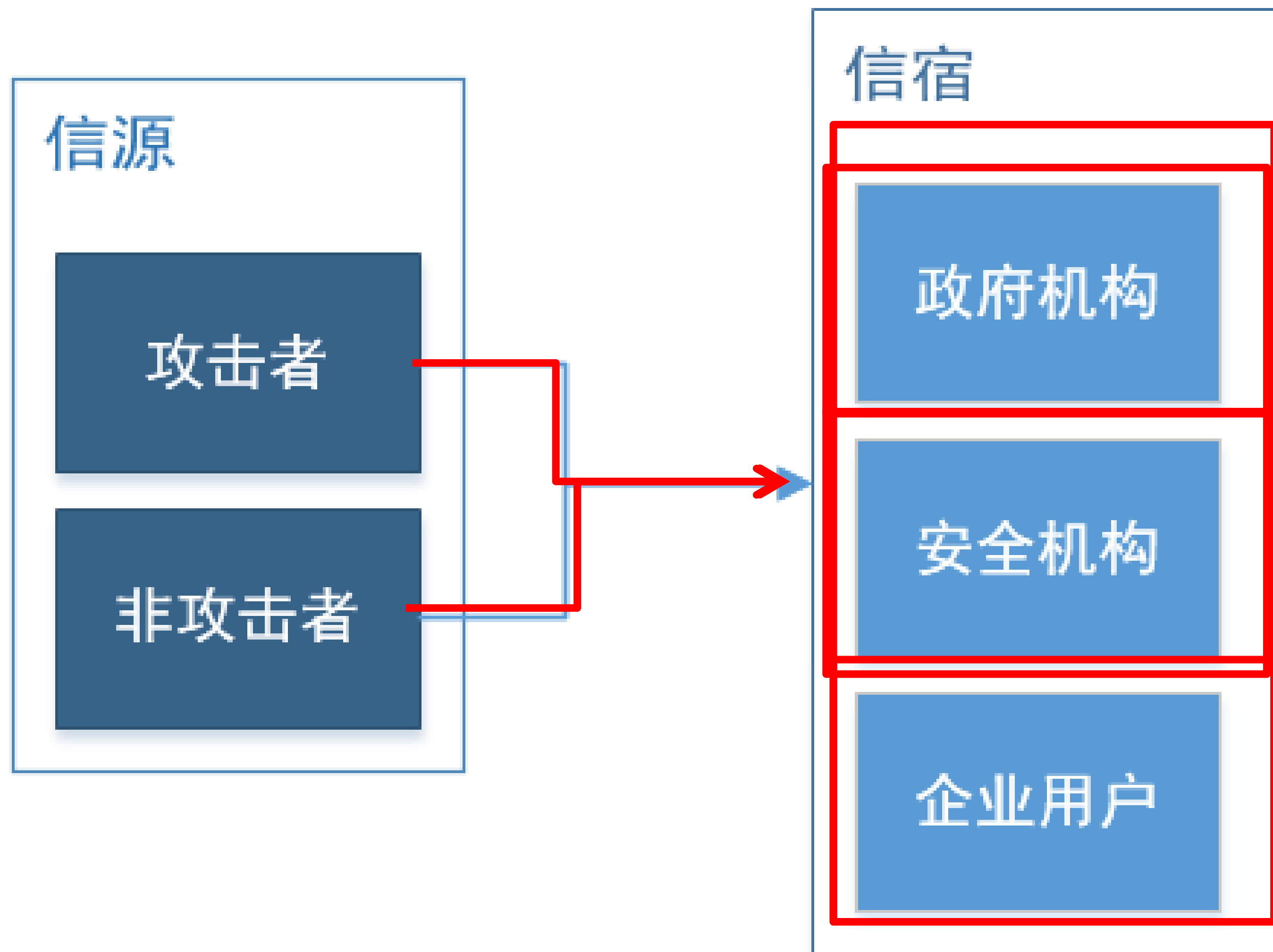
TOP SECRET

Safeguarding Canada's security through information superiority
Préserver la sécurité du Canada par la supériorité de l'information

TOP SECRET // COMINT // REL TO CAN, AUS, GBR, NZL, U

Canada

造成的影响



- 无论是发现同源还是判断归属，其核心还是关联溯源。



- 交叉验证：多维度、来源和时间
- 协同联动：政府机构、企业用户和安全厂商
- 人的价值：安全、数据和业务

- Email: 360zhuiqi@360.cn



Thank You!



中国互联网安全大会



360互联网安全中心